

The Practitioner's Blueprint for Secure AI

By John M. Willis, Quantum Powered Security, Inc.



August 2025

Copyright and License

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc.

This manuscript is licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0). You are free to share and adapt this work for any purpose, including commercial use, provided appropriate attribution is given.

License: <https://creativecommons.org/licenses/by/4.0/>

Patent Notice

The concepts, architectures, and reference designs presented in this work are intended to encourage adoption, adaptation, and further innovation. Readers are encouraged to tailor PBSAI to their own environments, products, and services. Novel implementations, extensions, and improvements developed by others may be eligible for intellectual property protection under applicable patent laws.

The authors likewise reserve all rights to pursue patent protection for their own inventions, implementations, improvements, and future developments related to PBSAI. Certain aspects of this work are the subject of pending patent applications. Except as expressly stated by applicable law, no patent rights are granted or implied by this publication or its CC BY 4.0 license.

Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem

Domain L – Security Program

Table of Contents

Domain L - Security Program Enablement	4
L1. Security Knowledge Agent	4
Agent Blueprint [Informative]	4
Technical Implementation Details (L1) [Informative]	14
MCP-Native Protocol Specification (L1) [Normative]	16
L2. Security Analytics Agent	17
Agent Blueprint [Informative]	17
Technical Implementation Details (L2) [Informative]	27
MCP-Native Protocol Specification (L2) [Normative]	29
L3. SOAR Orchestration Agent	30
Agent Blueprint [Informative]	30
Technical Implementation Details (L3) [Informative]	42
MCP-Native Protocol Specification (L3) [Normative]	44
L4. Data Curation Agent	45
Agent Blueprint [Informative]	45
Technical Implementation Details (L4) [Informative]	55
MCP-Native Protocol Specification (L4) [Normative]	57
L5. AI Validation Agent	58
Agent Blueprint [Informative]	58
Technical Implementation Details (L5) [Informative]	71
MCP-Native Protocol Specification (L5) [Normative]	73

Domain L - Security Program Enablement

L1. Security Knowledge Agent

Agent Blueprint [Informative]

Purpose: Maintain the enterprise security knowledge base (KB): normalize and version RCAs, playbooks, patterns, TTP mappings, and countermeasures; tag entries for mission/applicability and expose them to other agents.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **RCA Findings** (REST / S3-Blob / gRPC): incident/post-incident artifacts (root_cause, contributing_factors, controls_failed/effective, hardening_rec, evidence_uris, tags, timestamps, authors).
- **Playbooks** (Git over HTTPS/SSH; Markdown/JSON via REST): response runbooks and SOPs with owners, prerequisites, actions, rollback rules, evidence queries.

Model training / knowledge (what the LLM relies on):

- Style and rubric prompt-pack for KB entries (section headers, tone, YAML/JSON front-matter, cross-referencing standards).
- RAG sources: prior RCAs, approved playbooks, ATT&CK TTP catalog, control catalogs (NIST 800-53/CSF mappings), countermeasure patterns. Do not train on regulated evidence; use evidence_refs for on-demand retrieval.
- Guardrails: write scope limited to KB namespaces; deny direct edits to raw RCA blobs; constrained tools for Git, object store, knowledge store mutations.

Decisions it makes (deterministic + model-assisted):

- **Normalization:** convert source artifacts into canonical KB documents (front-matter fields, body sections, references).
- **Tagging and taxonomy:** assign mission/applicability tags, ATT&CK technique IDs, control mappings; validate against allowlists.
- **Versioning and deduplication:** compute similarity to existing entries, decide merge vs. new version vs. alias.
- **Classification & legal handling:** choose C1/C2/C3; mark legal_hold when RCA is compliance/forensics-bound.

- **Publishing:** decide when to write to KB and when to emit KBUUpdate events (create/update/reclassify/deprecate).

Routing / where outputs go:

- **KB document writes** → knowledge store (REST/GraphQL) with signed provenance; update search indices.
- **KBUUpdate events** → event bus (Kafka/AMQP/REST) for downstream agents (Detection, SOAR, EDR policy, Governance).
- **Tickets/alerts** → open review tasks when normalization fails, tagging confidence is low, or legal_hold conflicts exist.

Automation scope vs. manual/HITL:

- Fully automated: ingest, normalize, canonicalize, TTP/control tagging, dedup/versioning, KB write, event fan-out.
- **HITL required:** reclassification from C1 to C3; taxonomy changes (new tag families); conflicting hardening recommendations; legal_hold overrides.
- Manual outside agent: final SME approval for new countermeasure patterns; ratification of major playbook structural changes.

Security Domain: Security Program Enablement

Inputs (native protocols consumed) [Informative]

1. **RCA Findings (REST / S3-Blob / gRPC)** — structured incident/post-incident artifacts
2. **Playbooks (Git / Markdown-JSON via REST)** — response runbooks, SOPs

Example: Consumed Protocol — RCA Findings [Informative]

Native payload

```
{
  "rca_id": "RCA-2025-0815-0021",
  "incident_id": "INC-45877",
  "summary": "Unpatched Apache path traversal exploited; lateral movement blocked.",
  "root_cause": "vuln_unpatched",
  "contributing_factors": ["missing canary patch set on subset of prod"],
```

```

"controls_failed": ["SI-2", "CM-6"],
"effective_controls": ["SC-7 network segmentation", "PS-5 two-person approvals"],
"hardening_recs": [
  {"target": "linux_baseline", "change": "enable execve auditing"},
  {"target": "waf", "change": "tighten path traversal rules"}
],
"evidence_uris": [
  "s3://dfir/inc-45877/pcap.pcap",
  "s3://dfir/inc-45877/timeline.json"
],
"created": "2025-08-15T09:22:03Z",
"author": "dfir.jones",
"tags": ["ransomware", "linux", "web", "apache", "path-traversal"]
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-l1-kb-rca-1111-2222-3333-4444",
    "thread_id": "uuid-rca-RCA-2025-0815-0021",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "SecurityKnowledgeAgent",
    "intent": "curate",
    "tags": ["ransomware", "linux", "web", "apache", "path-traversal"],
    "policy_refs": ["IR-4", "SI-2", "CM-6", "SC-7", "PS-5"],
    "decision_basis": {
      "evidence_refs": [

```

```

    "uri://s3/dfir/inc-45877/pcap.pcap",
    "uri://s3/dfir/inc-45877/timeline.json",
    "uri://kb/rca/RCA-2025-0815-0021"
  ],
  "confidence": 0.96,
  "explanation_ref": "uri://kb/patterns/web/path-traversal-mitigations"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/program/knowledge-agent",
  "signing_kid": "kid-kb-l1-01",
  "attestation_ref": "uri://slsa/attestations/knowledge-agent@sha256:l1rca01"
},
"classification": "C3",
"legal_hold": true
},
"native_payload": { ... as above ... }
}

```

Example: Consumed Protocol — Playbooks [Informative]

Native payload

WAF Path Traversal Response Playbook

Preconditions

- Affected apps: apache/nginx fronted services
- Signals: SIEM alert "PathTraversalDetected", WAF rule SI-4-002

Actions

1. Validate alert in SIEM; fetch sample request path(s).

2. Enable strict normalization; block encoded traversal sequences.
3. Canary test against staging; monitor 15m.
4. Roll to prod in off-hours window; rollback if 5xx > 2% baseline.

Evidence

- SIEM search: detections for rule SI-4-002
- WAF logs: rule hits over time

Owners

- Network Security (primary), App Team (secondary)

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-l1-kb-pb-5555-6666-7777-8888",
    "thread_id": "uuid-playbook-waf-path-traversal",
    "task_id": "uuid-9911-8822-7733-6644",
    "role": "SecurityKnowledgeAgent",
    "intent": "curate",
    "tags": ["waf", "web", "path-traversal", "blue-team", "playbook"],
    "policy_refs": ["IR-4", "CP-2", "SI-4"],
    "decision_basis": {
      "evidence_refs": ["uri://git/runbooks/waf/path-traversal.md@v2.1"],
      "confidence": 0.94,
      "explanation_ref": "uri://kb/playbooks/authoring-standards#canary-and-rollback"
    },
    "provenance": {
```

```

    "producer_spiffe": "spiffe://enterprise/program/knowledge-agent",
    "signing_kid": "kid-kb-l1-02",
    "attestation_ref": "uri://slsa/attestations/knowledge-agent@sha256:l1pb02"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": "<markdown body omitted for brevity>"
}

```

Outputs (native) [Informative]

- **KB document writes** to the knowledge store (REST/GraphQL).
- **KBUpdate events** to downstream agents via Kafka/AMQP/REST.

MCP context (required) [Informative]

mission_id; role="SecurityKnowledgeAgent"; intent="curate"; tags=[...]; provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

policy_refs; classification (C1–C3); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

Knowledge store and consuming PEPs must verify provenance.attestation and honor **classification** and **legal_hold**. Fan-out of C3 artifacts must respect data-locality and legal-hold restrictions.

NIST SP 800-160v2 linkage [Informative]

Maintain & Evolve — institutionalize learnings, patterns, and design principles for resiliency.

Automation feasibility [Informative]

High (ingest/normalize/tag/version fully automatable; SME review for final approvals).

Output Contracts (merged) [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

OC-1: KBWriteOperation (KB document write) [Informative]

- **Producer(s):** L1
- **Endpoint/Path:** POST /kb/documents or GraphQL mutation kbUpsert(doc)
- **Schema/Format:** KBWrite@1.0 (front-matter + body + refs)
- **Classification:** C1 default; C2 for sensitive architecture; C3 for regulated/identifiable RCA content
- **Delivery:** exactly-once per (doc_id, version)
- **Ordering:** per-doc_id
- **Idempotency-Key:** sha256(doc_id, version)
- **Ack/Nack:** HTTP 200/201 or GraphQL success; NACK = 4xx/5xx with error_code
- **Timeouts/Retry:** ack<=30s; exp-backoff<=5x; circuit-break on store errors
- **Side-Effects:** index update, search refresh, backlinks regeneration
- **HITL Token:** required for C3 writes or taxonomy mutations
- **Observability:** trace_id, mission_id, tags, ttp_refs, policy_refs, classification_label, provenance.attestation
- **Retention/TTL:** per classification; legal_hold overrides TTL

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=KBWrite@1.0 | json_schema_uri=uri://schema/kb-write-1.0.json | sha256= | producers=L1 | consumers=KBStore-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: KBUpdateEvent (create/update/reclassify/deprecate) [Informative]

- **Producer(s):** L1
- **Topic/Path:** sec.kb.update (Kafka/AMQP or REST callback)
- **Schema/Format:** KBUpdateEvent@1.0 (event_type, doc_id, version, tags, ttp_refs, summary, links)

- **Classification:** C1–C3 mirrors doc classification; fan-out constrained by data-locality
- **Delivery:** at-least-once
- **Ordering:** per-doc_id
- **Idempotency-Key:** sha256(doc_id, version, event_type)
- **Ack/Nack:** broker ACK or REST 2xx; NACK triggers retry/backoff
- **Timeouts/Retry:** ack<=10s; exp-backoff<=7x
- **Side-Effects:** notify subscribers (Detection, SOAR, Governance); invalidate caches
- **HITL Token:** required when event includes reclassification to C3
- **Observability:** trace_id, mission_id, tags, ttp_refs, decision_basis.summary_ref, provenance.attestation
- **Retention/TTL:** 1 year (events), documents per KB policy

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When downstream subscription or sync is enabled, or any approved KB change occurs

schema_id=KBUpdateEvent@1.0 | json_schema_uri=uri://schema/kb-update-event-1.0.json | sha256= | producers=L1 | consumers=SOAR-01, DET-01, GOV-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Review portals; L1 (aggregation)
- **Topic/Path:** sec.kb.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (review_id, artifact_id, rating, labels, comment_ref)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review-id
- **Idempotency-Key:** sha256(review_id, artifact_id)

- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** enqueue for governance-reviewed prompt/rubric updates
- **Observability:** trace_id, mission_id, artifact_id, labels={helpful|neutral|harmful}
- **Retention/TTL:** 1 year (or per HR/Legal)

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, ingesting_rca, ingesting_playbook, normalizing, tagging, mapping_ttp, deduplicating, writing, notifying, contestation_workflow, failed, closed }

transition(idle -> ingesting_rca) when RCA artifact arrives

transition(idle -> ingesting_playbook) when playbook change detected

transition(ingesting_* -> normalizing) when schema validated

transition(normalizing -> tagging) when canonical form created

transition(tagging -> mapping_ttp) when tags assigned

transition(mapping_ttp -> deduplicating) when TTP/control mappings done

transition(deduplicating -> writing) when similarity_below_threshold or alias decided

transition(writing -> notifying) when KB write ACKed

transition(* -> contestation_workflow) when dispute opened or low confidence and stakeholder_disagreement_score >= 0.5

transition(* -> failed) on timeout or validation error

timeout(writing, 30s) -> failed; retry <= 5 with exp backoff

idempotency_key = sha256(doc_id, version) for writes; sha256(doc_id, version, event_type) for updates

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 KBWriteOperation	Required	Always	Source of truth in KB
OC-2 KBUpdateEvent	Conditionally Required	Any approved KB create/update/reclassify/deprecate	Downstream sync to agents
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow enabled	Continuous improvement of KB

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: IR-4, CP-2, SI-3, PM-9 (+ internal standards)
- **HITL required:** C3 writes; reclassification to C3; taxonomy changes; contradictory hardening recommendations.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; stakeholder_disagreement_score >= 0.5; legal_hold=true with attempted purge.
- **Manual outside agent:** major taxonomy revisions; KB-wide deprecation campaigns.

SLOs and KPIs [Informative]

- KBWriteAck_p95 <= 30 s
- UpdateFanoutAck_p95 <= 10 s
- TagPrecision_28d >= 95 percent
- TTPMappingCoverage >= 90 percent for new RCAs
- DedupRecall_28d >= 90 percent; DedupPrecision_28d >= 98 percent

- KnowledgeStalenessMedian <= 30 days for hot tags (e.g., ransomware)

Outputs index [Informative]

[OC-1 KBWriteOperation], [OC-2 KBUpdateEvent], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (L1) [Informative]

Model and training profile [Informative]

model_id=kb-curator-text; temperature=0.1; max_tokens_out=900
 prompt_pack_id=kb-authoring-v1 (canonical sectioning, tagging rubric, cross-ref rules)
 RAG: sources={approved RCAs, playbooks, ATT&CK catalog, control catalogs, countermeasure patterns}; max_docs=10; min_similarity=0.78; citations required
 fine_tuning/adapters: none initially; if added, exclude regulated evidence; eval gates on tagging accuracy and hallucination bounds
 guardrails: namespace allowlist for writes; deny edits to raw incident artifacts; scoped tokens for KB store and repos

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal (ingest decisions, versions, events), ttl=365d
 semantic_memory: namespaces=["rca", "playbooks", "patterns", "controls", "ttp"];
 embeddings=text-embedding-sec-v1; k=10
 durable_state_store: event-sourced journal; snapshot on version publish
 consistency: exactly-once (writes); at-least-once (events)
 idempotency: as per Output Contracts

Decision and routing logic [Informative]

similarity = cosine(embedding(new_doc), embedding(corpus_top_k))
 dedup_if similarity >= 0.92 and doc_type == prior.doc_type
 alias_if 0.85 <= similarity < 0.92 and tags overlap >= 60 percent
 classification_choice = max(required_classification_from_sources, inferred_classification_from_content)
 publish_if validation_pass == true and (HITL_required == false or HITL_approved == true)

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens for tagging, adversarial prompt tests, jailbreak]
 thresholds: tagging_f1_7d >= 0.95 → else auto_HITL and rollback to last good

prompt_pack

red_team_cycle: monthly (ATT&CK-inspired) against tagging/classification and provenance spoof checks

rollback_policy: if eval_drop >= 1.5 percentage points for 48 h → revert prompt_pack_id or model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who, what, why; evidence_refs; control_mappings; ttp_refs; hashes

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL; retention per classification; legal_hold pinning

Incident Response Integration [Informative]

on RCA ingest, link incident_id and attach evidence_refs; emit KBUUpdateEvent so SOAR enrichers and Detection generators can subscribe

Change Impact Assessment [Informative]

impact_on_playbooks = count(affected_playbooks_by_tag $\cap$ new_tags)

raise_review_if impact_on_playbooks >= threshold

Stakeholder Feedback Loop [Informative]

capture ratings/comments via FeedbackIngestionEvent; after governance review, update prompt_pack or tagging rules (no auto-training on regulated evidence)

Data Sovereignty and Legal Hold [Informative]

enforce region tags on KB writes and subscription fan-out; legal_hold=true blocks purge and restricts redistribution to compliant regions

Interfaces (links only) [Informative]

Consumes: RCA Findings (REST/S3/gRPC); Playbooks (Git/REST)

Produces: OC-1, OC-2, OC-6

Safety and abuse prevention [Informative]

kill_switch on signature or schema validation failures; rate limits per mission_id; content scanning to prevent sensitive leakage in C1

Testing and validation [Informative]

contract tests for OC-1/OC-2/OC-6; offline replay of historical RCAs/playbook diffs; red-team taxonomy poisoning attempts; drift checks and rollback

Deployment and lifecycle [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

scale on ingest queue depth; canary new normalization rules; SBOM + attestations; signed outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5; NIST CSF 2.0; NIST SP 800-61 Rev. 2; NIST SP 800-137; MITRE ATT&CK/D3FEND; ISO/IEC 27002:2022; CIS v8

MCP-Native Protocol Specification (L1) [Normative]

- **Native Protocol(s) Consumed:**
 - RCA Findings (REST / S3-Blob / gRPC) — structured incident/post-incident artifacts
 - Playbooks (Git over HTTPS/SSH; Markdown/JSON via REST) — response runbooks, SOPs
- **Native Protocol(s) Produced:**
 - KBUdate events (Kafka/AMQP/REST) to downstream agents
 - KB document writes (REST/GraphQL) to the knowledge store
- **MCP Context Fields:**
 - **Required:** mission_id; role="SecurityKnowledgeAgent"; intent="curate"; tags=[...]; provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** policy_refs; classification (C1–C3); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold
- **Enforcement Note:** Consumers must verify provenance.attestation; must enforce classification and legal_hold; region-aware subscription required for C3.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** authoritative native + MCP-wrapped examples as provided above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

L2. Security Analytics Agent

Agent Blueprint [Informative]

Purpose: Aggregate and analyze program metrics and longitudinal trends (e.g., MTDD, MTTR, patch latency, containment success, control coverage). Generate **AnalyticsReport** for executives and control owners with defensible formulas and evidence references.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **MetricsAggregator** (Kafka/AMQP MetricSnapshot or OTLP pull): precomputed KPIs/SLOs and raw OTLP counters with source pointers and window boundaries.
- **ActionOutcome** (Kafka/AMQP): per-action results (containment, patch, change, etc.) including timestamps, results, initiator, and linkage to detections.

Model training / knowledge (what the LLM relies on):

- Analytics prompt-pack with formula catalog, glossary, visual style guide, and slicing rules (env, business unit, control family).
- RAG sources: metric snapshots, incident dataset catalog, control coverage inventory, formula registry; citations via evidence_refs.
- Guardrails: read-only access to raw signals; write scope limited to AnalyticsReport endpoints and Findings topics; enforced constraint “no_pii”.

Decisions it makes (deterministic + model-assisted):

- Calculate and validate KPIs per declared formulas; cross-check for missing data and window gaps.
- Detect outliers/regressions vs. baselines; compute effect sizes and significance where applicable.
- Recommend actions (e.g., accelerate patch lanes, tune containment playbooks) with explicit evidence trails.
- Classify report sensitivity (C1–C2) and honor publish_window constraints.

Routing / where outputs go:

- **AnalyticsReport** → REST/GraphQL (exec + owner views) or Kafka topic for consumers.

- **AnalyticsFinding** (optional) → events bus for SOAR/SIEM/owners when thresholds breach.
- **Tickets/alerts** → create issues when SLOs breached or data quality fails validation.

Automation scope vs. manual/HITL:

- Fully automated: ingestion, computation, validation, baseline comparison, report generation, publish.
- **HITL required:** formula changes, KPI definition updates, retroactive reclassification, publication of C2 material to broad audiences.
- Manual outside agent: quarterly KPI target resets; executive narration edits (if desired).

Security Domain: Security Program Enablement

Inputs (native protocols consumed) [Informative]

1. **MetricsAggregator (MetricSnapshot)** — computed KPIs and SLOs
2. **ActionOutcome** — results of containment, patch, change, and other actions

Example: Consumed Protocol — MetricsAggregator (MetricSnapshot) [Informative]

Native payload

```
{
  "metric_snapshot_id": "MS-2025-08-15-001",
  "window": "2025-08-08T00:00:00Z/2025-08-15T00:00:00Z",
  "metrics": [
    {"name": "MTTD_minutes", "value": 1.53, "slice": {"env": "production"}},
    {"name": "MTTR_minutes", "value": 16.88, "slice": {"env": "production"}},
    {"name": "PatchLatency_p90_hours", "value": 40.2, "slice": {"cvss_bucket": "9.0_plus"}},
    {"name": "ContainmentSuccess_rate", "value": 0.972, "slice": {"family": "malware"}},
    {"name": "ControlCoverage_percent", "value": 98.7, "slice": {"control": "endpoint-protection"}}
  ],
}
```

```

"sources": [
  "uri://incident/api/incidents",
  "uri://kafka/containment/actions",
  "uri://otel/metrics/*"
],
"generated_at": "2025-08-15T00:10:00Z"
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-l2-analytics-1111-2222-3333-4444",
    "thread_id": "uuid-ms-MS-2025-08-15-001",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "SecurityAnalyticsAgent",
    "intent": "analyze",
    "policy_refs": ["PM-5", "IR-4", "SI-4", "CM-6"],
    "constraints": ["no_pii", "publish_window:weekly"],
    "decision_basis": {
      "evidence_refs": [
        "uri://kafka/metricssnapshots/MS-2025-08-15-001",
        "uri://incident/api/incidents",
        "uri://otel/metrics/*"
      ],
      "formulas": [
        "MTTD_minutes = mean( detect_ts - compromise_ts ) in minutes over incidents
        within window",

```

```
"MTTR_minutes = mean( restore_ts - detect_ts ) in minutes over incidents within window",
```

```
"PatchLatency_p90_hours = percentile90( patch_completed_ts - advisory_released_ts ) in hours",
```

```
"ContainmentSuccess_rate = successful_containments / total_containments",
```

```
"Coverage_gap_rate = 1 - ( ControlCoverage_percent / 100 )"
```

```
],
```

```
"confidence": 0.97,
```

```
"explanation_ref": "uri://docs/analytics/formulas-v1"
```

```
},
```

```
"provenance": {
```

```
  "producer_spiffe": "spiffe://enterprise/program/security-analytics-agent",
```

```
  "signing_kid": "kid-l2-ms-01",
```

```
  "attestation_ref": "uri://slsa/attestations/security-analytics@sha256:ms01"
```

```
},
```

```
"classification": "C1",
```

```
"legal_hold": false
```

```
},
```

```
"native_payload": { /* same as Native Payload above */ }
```

```
}
```

Example: Consumed Protocol — ActionOutcome [Informative]

Native payload

```
{
```

```
  "action_id": "ACT-2025-0815-0045",
```

```
  "action": "isolate_host",
```

```
  "result": "success",
```

```
  "asset_id": "srv-001",
```

```
  "requested_ts": "2025-08-15T10:01:05Z",
```

```
"completed_ts": "2025-08-15T10:01:23Z",
"latency_ms": 18000,
"initiator": "AutomatedContainmentAgent",
"related_detection_id": "DET-2025-0815-7711"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-l2-analytics-5555-6666-7777-8888",
    "thread_id": "uuid-actout-ACT-2025-0815-0045",
    "task_id": "uuid-9911-8822-7733-6644",
    "role": "SecurityAnalyticsAgent",
    "intent": "analyze",
    "policy_refs": ["PM-5", "IR-4"],
    "constraints": ["no_pii"],
    "decision_basis": {
      "evidence_refs": [
        "uri://kafka/actionoutcome/ACT-2025-0815-0045",
        "uri://detections/DET-2025-0815-7711"
      ],
      "formulas": [
        "Containment_latency_seconds = ( completed_ts - requested_ts ) in seconds",
        "Containment_success = 1 if result == 'success' else 0",
        "ContainmentSuccess_rate = sum(Containment_success) / count(ActionOutcome
where action == 'isolate_host' within window)"
      ]
    }
  }
}
```

```

    "confidence": 0.98,
    "explanation_ref": "uri://docs/analytics/containment-kpis"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/program/security-analytics-agent",
    "signing_kid": "kid-l2-act-02",
    "attestation_ref": "uri://slsa/attestations/security-analytics@sha256:act02"
  },
  "classification": "C1",
  "legal_hold": false
},
"native_payload": { /* same as Native Payload above */ }
}

```

Outputs (native) [Informative]

- **AnalyticsReport** (REST/GraphQL or Kafka).
- **AnalyticsFinding** events for outliers/regressions (optional).

MCP context (required) [Informative]

mission_id; role="SecurityAnalyticsAgent"; intent="analyze"; decision_basis (formulas + evidence_refs); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

policy_refs; classification (C1–C2 typical); constraints (e.g., "no_pii", "publish_window:weekly"); legal_hold

Enforcement note [Informative]

Consumers must verify provenance.attestation, honor **constraints** (e.g., no_pii) and **classification** on report distribution; PEPs should block publication outside publish_window.

NIST SP 800-160v2 linkage [Informative]

Evaluate & Maintain — measurement and improvement for resilience. Also aligns to **NIST SP 800-137 ISCM**.

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

Automation feasibility [Informative]

High (formulaic computation and reporting are automatable; thresholds set by governance).

Output Contracts (merged) [Informative]

OC-1: AnalyticsReport [Informative]

- **Producer(s):** L2
- **Endpoint/Path:** POST /analytics/report (REST) or analytics.reports (Kafka); GraphQL mutation publishReport(report)
- **Schema/Format:** AnalyticsReport@1.0 (window, slices, metrics, trends, formulas, evidence_refs, narrative)
- **Classification:** C1 (default) or C2 when sensitive operational detail included
- **Delivery:** exactly-once per (report_id, window)
- **Ordering:** per-window_start
- **Idempotency-Key:** sha256(report_id, window_start, window_end)
- **Ack/Nack:** REST 201/GraphQL success/broker ACK; NACK = 4xx/5xx with error_code
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; open ticket on repeated failure
- **Side-Effects:** persist to report registry; update dashboards; attach formula digest map
- **HITL Token:** required for C2, or if formulas changed since last publish
- **Observability:** trace_id, mission_id, decision_basis.formulas, evidence_refs, classification_label, provenance.attestation
- **Retention/TTL:** 3 years (or per policy)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=AnalyticsReport@1.0 | json_schema_uri=uri://schema/analytics-report-1.0.json | sha256= | producers=L2 | consumers=ExecPortal-01, ControlOwner-01, DataWarehouse-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: AnalyticsFinding (outlier/regression/SLO_breach) [Informative]

- **Producer(s):** L2
- **Topic/Path:** sec.analytics.finding (Kafka/AMQP) or POST /analytics/finding
- **Schema/Format:** AnalyticsFinding@1.0 (finding_id, kind, metric_name, value, baseline, threshold, window, significance_p, effect_size, impacted_entities, suggested_action_ref)
- **Classification:** C1 by default; C2 if incident-linked
- **Delivery:** at-least-once
- **Ordering:** per-metric_name
- **Idempotency-Key:** sha256(metric_name, window_start, window_end, kind)
- **Ack/Nack:** broker ACK/REST 2xx; retries with backoff on failure
- **Timeouts/Retry:** ack<=10s; exp-backoff<=7x; dedupe on idempotency_key
- **Side-Effects:** open SOAR/SIEM case when severity >= high; notify owners
- **HITL Token:** required if suggested_action_ref implies production-impacting change
- **Observability:** trace_id, mission_id, decision_basis.formulas, evidence_refs, severity, classification_label
- **Retention/TTL:** 1 year

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When outlier/regression detection is enabled or thresholds are defined
schema_id=AnalyticsFinding@1.0 | json_schema_uri=uri://schema/analytics-finding-1.0.json | sha256= | producers=L2 | consumers=SOAR-01, SIEM-01, ControlOwner-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-6: FeedbackIngestionEvent (stakeholder review of analytics) [Informative, optional]

- **Producer(s):** Review portals; L2 (aggregation)
- **Topic/Path:** sec.analytics.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (review_id, report_id, rating, labels, comment_ref)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review-id
- **Idempotency-Key:** sha256(review_id, report_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** enqueue rubric update proposal; do not auto-train on regulated content
- **Observability:** trace_id, mission_id, report_id, labels={helpful|neutral|harmful}
- **Retention/TTL:** 1 year

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

```

states = { idle, ingesting_metrics, joining_actions, computing, validating,
generating_report, publishing, emitting_findings, contestation_workflow, failed, closed }
transition(idle -> ingesting_metrics) when MetricSnapshot received
transition(ingesting_metrics -> joining_actions) when ActionOutcome window overlap
present
transition(joining_actions -> computing) when joins succeed
transition(computing -> validating) when metrics computed
transition(validating -> generating_report) when validation_pass == true
transition(generating_report -> publishing) when report compiled
transition(publishing -> emitting_findings) when thresholds or regressions detected
transition(* -> contestation_workflow) when report disputed or data_quality_score <
theta
transition(* -> failed) on timeout or schema/provenance error

```

timeout(publishing, 60s) -> failed; retry <= 5 with exp backoff
idempotency_key = sha256(report_id, window_start, window_end) for reports;
sha256(metric_name, window_start, window_end, kind) for findings

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 AnalyticsReport	Required	Always	Executive/control-owner visibility
OC-2 AnalyticsFinding	Conditionally Required	Outlier/regression detection enabled or thresholds defined	Rapid remediation and SLO governance
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow enabled	Continuous improvement of analytics

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
 - **Conditionally Required:** Must be implemented when trigger condition is met
 - **Optional:** May be implemented for enhanced functionality
-

Policies and HITL gates [Informative]

- policy_refs: PM-5 (Program Mgmt), IR-4, SI-4, CM-6 (+ internal KPI policy).
- **HITL required:** formula or target changes; C2 publication; any suggested_action_ref that impacts production.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; data_quality_score < 0.9; regression_severity >= high.

SLOs and KPIs [Informative]

- ReportPublishAck_p95 <= 60 s
- MetricStaleness_p95 <= 24 h

- FormulaTraceabilityCoverage = 100 percent (reports must include formulas and evidence_refs)
- FalseRegressionRate_30d <= 2 percent
- DataQualityValidationPassRate_30d >= 99 percent

Outputs index [Informative]

[OC-1 AnalyticsReport], [OC-2 AnalyticsFinding], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (L2) [Informative]

Model and training profile [Informative]

model_id=analytics-text-model; temperature=0.1; max_tokens_out=900
 prompt_pack_id=analytics-v1 (formula catalog, glossary, narrative templates)
 RAG: sources={metric snapshots, incidents API, OTLP metrics index, formula registry};
 max_docs=12; min_similarity=0.78; citations required
 fine_tuning/adapters: none initial; if added, exclude PII and regulated evidence; eval on
 formula fidelity and hallucination bounds
 guardrails: enforce constraints={"no_pii", publish_window}; signed outputs

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal (windows, joins, validations), ttl=365d
 semantic_memory: namespaces=["kpis","formulas","baselines"]; embeddings=text-
 embedding-sec-v1; k=10
 durable_state_store: event-sourced; snapshot on each published report
 consistency: exactly-once (reports); at-least-once (findings)
 idempotency: as per Output Contracts

Decision and routing logic [Informative]

MTTD_minutes = mean(detect_ts - compromise_ts) in minutes over incidents within
 window
 MTTR_minutes = mean(restore_ts - detect_ts) in minutes over incidents within window
 PatchLatency_p90_hours = percentile90(patch_completed_ts - advisory_released_ts)
 in hours
 ContainmentSuccess_rate = successful_containments / total_containments
 Coverage_gap_rate = 1 - (ControlCoverage_percent / 100)
 regression_severity = f(effect_size, significance_p, delta_from_baseline,

business_impact_weight)
publish_if validation_pass == true and within_publish_window == true

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens for formulas, adversarial prompts, jailbreak]
thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below
red_team_cycle: monthly probes on metric tampering and provenance spoofing
rollback_policy: if eval_drop >= 1.5 percentage points for 48 h → revert model_id or prompt_pack_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: metrics computed, formulas, evidence_refs, deltas vs. baseline, assumptions
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL with stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

emit AnalyticsFinding for SLO breach; tag finding with incident family and control owner; optionally open SOAR case

Change Impact Assessment [Informative]

estimate impact_on_controls = sum(risk_weight(control) * delta(metric_for_control))
raise_review_if impact_on_controls >= threshold

Stakeholder Feedback Loop [Informative]

collect ratings/comments via FeedbackIngestionEvent; governance reviews updates to formula catalog (no auto-training on regulated evidence)

Data Sovereignty and Legal Hold [Informative]

enforce region-aware distribution; only C1 permitted to broad audiences by default;
legal_hold=true blocks purge and redistribution

Interfaces (links only) [Informative]

Consumes: MetricsAggregator (MetricSnapshot); ActionOutcome
Produces: OC-1, OC-2, OC-6

Safety and abuse prevention [Informative]

kill_switch on provenance or schema validation failure; rate limits per mission_id; guard against PII leakage in narratives

Testing and validation [Informative]

contract tests for OC-1/OC-2/OC-6; offline replay across past windows; synthetic outlier injection; drift checks and rollback

Deployment and lifecycle [Informative]

scale on snapshot volume; canary formula changes; SBOM + attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-137 (ISCM); NIST SP 800-53 Rev. 5; NIST CSF 2.0; ISO/IEC 27002:2022; MITRE ATT&CK/D3FEND; CIS v8

MCP-Native Protocol Specification (L2) [Normative]

- **Native Protocol(s) Consumed:**
 - MetricsAggregator (Kafka/AMQP MetricSnapshot or OTLP pull) — computed KPIs and SLOs
 - ActionOutcome (Kafka/AMQP) — results of containment, patch, change, and other actions
- **Native Protocol(s) Produced:**
 - AnalyticsReport (REST/GraphQL or Kafka)
 - AnalyticsFinding events (optional)
- **MCP Context Fields:**
 - **Required:** mission_id; role="SecurityAnalyticsAgent"; intent="analyze"; decision_basis (formulas + evidence_refs); provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** policy_refs; classification (C1–C2); constraints (e.g., "no_pii", "publish_window:weekly"); legal_hold
- **Enforcement Note:** PEPs must verify provenance and enforce constraints (no_pii, publish_window) and classification at distribution time.

- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** authoritative native + MCP-wrapped examples as provided above.
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

L3. SOAR Orchestration Agent

Agent Blueprint [Informative]

Purpose: Coordinate multi-agent response workflows end-to-end (e.g., isolate host, revoke tokens, collect evidence, patch/rollback), enforce sequencing/parallelism, and manage HITL gates and deadlines.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **DetectionEvent** (Kafka/AMQP or REST): detector output from SIEM/EDR/IDS (entities, indicators, severity, confidence, `recommended_playbook`).
- **ContainmentCommand** (REST/Kafka): operator or policy-engine directive (targets, steps, `parallel_groups`, rollback, time budget, approvals).

Model training / knowledge (what the LLM relies on):

- Orchestration prompt-pack: runbook grammar, constraint resolution, parallelism rules, failure/retry policies, escalation routes, and A1 policy co-sign semantics.
- RAG sources: approved playbooks, responder agent capability registry, PEP/constraint catalog (deadlines, `max_concurrency`), and governance rules (two-person control, co-sign prerequisites).
- Guardrails: constrain tool calls to the Responder API allowlist; enforce declared constraints (deadline, `parallel_group`, sequence); **never** execute protected actions without verified A1 PolicyCoSign.

Decisions it makes (deterministic + model-assisted):

- **Plan & schedule:** expand selected playbook to an executable DAG; compute valid parallel groups; order steps with dependencies and time-budget slicing.

- **Gate & verify:** check **co-sign** presence for protected actions; enforce HITL gates; verify approvals.
- **Dispatch & monitor:** send **WorkflowTaskDispatch** to responder agents; track acks, retries, timeouts; choose rollback on failure according to policy.
- **Escalate & close:** raise **HITLApprovalRequest** or **EscalationEvent** on breach; close runbook, emit status/completion, and hand off to DFIR/Analytics as needed.

Routing / where outputs go:

- **WorkflowTaskDispatch** → REST/gRPC to responder agents (Containment, EDR Action, Evidence Collector, Patch, IdP, Cloud Snapshot).
- **RunbookStatusEvent** / **RunbookCompletedEvent** → Kafka/AMQP for subscribers (IR portal, SIEM, Analytics L2, Governance A1).
- **HITLApprovalRequest** → Ticketing/ChatOps when gate encountered or risk thresholds triggered.

Automation scope vs. manual/HITL:

- Fully automated: DAG construction, dispatch, retries, deadline tracking, rollback execution, status/telemetry emission.
- **HITL required:** any step flagged as protected (e.g., `disable_account` on CrownJewels) without valid co-sign; actions with `blast_radius > threshold`; post-failure irreversible steps.
- Manual outside agent: exception handling for non-standard assets; approval-policy changes; bespoke legal/PR coordination.

Security Domain: Security Program Enablement

Inputs (native protocols consumed) [Informative]

1. **DetectionEvent (SIEM/EDR/IDS)** — detector outputs
2. **ContainmentCommand** — operator/policy directive

Example: Consumed Protocol — DetectionEvent [Informative]

Native payload

```
{
  "detection_id": "DET-2025-0815-7711",
```

```

"source": "EDR",
"rule": "Ransomware Encryptor Behavior",
"severity": "High",
"timestamp": "2025-08-15T10:00:12Z",
"entities": {
  "host": "srv-001",
  "user": "E102993",
  "process": {"name": "encryptor.exe", "pid": 4321, "sha256": "abc..."},
  "ip": "10.2.14.5"
},
"indicators": ["file_encrypt_spike", "shadow_copy_delete"],
"confidence": 0.93,
"recommended_playbook": "PB-WIN-Ransomware-Contain-Collect"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-l3-soar-1111-2222-3333-4444",
    "thread_id": "uuid-det-DET-2025-0815-7711",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "SOAROrchestrationAgent",
    "intent": "orchestrate",
    "policy_refs": ["IR-4", "IR-5", "SI-4"],
    "constraints": [
      "sequence:isolate_host->token_revoke->snapshot_disk->collect_memory-
>eradicate->restore",
    ]
  }
}

```

```

    "parallel_group:iso|token_revoke",
    "max_concurrency:5",
    "deadline:900s",
    "hitl_gate:before_eradicate"
  ],
  "decision_basis": {
    "evidence_refs": [
      "uri://kafka/detections/DET-2025-0815-7711",
      "uri://kb/playbooks/PB-WIN-Ransomware-Contain-Collect"
    ],
    "confidence": 0.92,
    "explanation_ref": "uri://kb/runbooks/ransomware-critical-path"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/program/soar-orchestrator",
    "signing_kid": "kid-det-l3-01",
    "attestation_ref": "uri://slsa/attestations/soar@sha256:det01"
  },
  "classification": "C2",
  "legal_hold": true
},
"native_payload": { /* same as Native Payload above */ }
}

```

Example: Consumed Protocol — ContainmentCommand [Informative]

Native payload

```

{
  "command_id": "CMD-2025-0815-0009",

```

```

"origin": "IncidentCommander",
"playbook_id": "PB-WIN-Ransomware-Contain-Collect",
"targets": [{"asset_id": "srv-001", "user": "E102993"}],
"steps": [
  {"id": "iso", "action": "isolate_host", "agent": "AutomatedContainmentAgent"},
  {"id": "revoke", "action": "disable_user_tokens", "agent": "IdPControlAgent"},
  {"id": "snap", "action": "snapshot_disk", "agent": "CloudSnapshotAgent"},
  {"id": "mem", "action": "collect_memory", "agent": "EvidenceCollectorAgent"},
  {"id": "erad", "action": "kill_process", "args": {"pid": 4321}, "agent":
"EDRActionAgent"},
  {"id": "restore", "action": "restore_network", "agent": "AutomatedContainmentAgent"}
],
"parallel_groups": [{"iso", "revoke"}, {"snap", "mem"}],
"rollback_policy": {"on_fail": ["restore"]},
"time_budget_seconds": 900,
"approvals": ["sec.lead"]
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-l3-soar-5555-6666-7777-8888",
    "thread_id": "uuid-cmd-CMD-2025-0815-0009",
    "task_id": "uuid-9911-8822-7733-6644",
    "role": "SOAROrchestrationAgent",
    "intent": "orchestrate",
    "policy_refs": ["IR-4", "CP-2", "PS-5"],

```

```

"constraints": [
  "sequence:iso->revoke->snap|mem->erad->restore",
  "parallel_group:iso|revoke",
  "parallel_group:snap|mem",
  "max_concurrency:4",
  "deadline:900s",
  "hitl_gate:before_eradicate",
  "rollback:on_fail=restore"
],
"decision_basis": {
  "evidence_refs": [
    "uri://commands/CMD-2025-0815-0009",
    "uri://kb/playbooks/PB-WIN-Ransomware-Contain-Collect"
  ],
  "confidence": 0.95,
  "explanation_ref": "uri://kb/orchestration/constraints-and-sequencing"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/program/soar-orchestrator",
  "signing_kid": "kid-cmd-l3-02",
  "attestation_ref": "uri://slsa/attestations/soar@sha256:cmd02"
},
"classification": "C2",
"legal_hold": true
},
"native_payload": { /* same as Native Payload above */ }
}

```

Outputs (native) [Informative]

- Workflow tasks to responder agents via REST/gRPC (Containment/EvidenceCollector/Patch/etc.).
- Kafka/AMQP: RunbookStarted, WorkflowTaskDispatched, RunbookStatus, RunbookCompleted.
- Ticketing/ChatOps updates (optional).

MCP context (required) [Informative]

mission_id; role="SOAROrchestrationAgent"; intent="orchestrate"; constraints (sequence/parallel/deadline/concurrency/HITL); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

policy_refs (IR-4, IR-5, CP-2, SI-4); classification (C1–C3); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

PEPs MUST verify: (1) **A1 PolicyCoSign** for protected actions; (2) declared **constraints** (sequence, deadline, max_concurrency, HITL gates) before executing steps; (3) provenance.attestation on all dispatches and events.

NIST SP 800-160v2 linkage [Informative]

Implement / Maintain resilient response orchestration; aligns with **NIST SP 800-61 (IR)** and **SP 800-137 (ISCM)**.

Automation feasibility [Informative]

High (full automation with explicit HITL stops at configured risk thresholds).

Output Contracts (merged) [Informative]

OC-1: WorkflowTaskDispatch (to responder agents) [Informative]

- **Producer(s)**: L3
- **Endpoint/Path**: POST /tasks/dispatch (REST) or gRPC Dispatch(Task) to responder agents
- **Schema/Format**: WorkflowTaskDispatch@1.0 (runbook_id, step_id, action, target_set, args, depends_on, parallel_group, deadline_s, retry_policy, approvals, cosign_metadata)

- **Classification:** C2 (may embed asset identifiers)
- **Delivery:** exactly-once per (runbook_id, step_id) (consumer enforces idempotency)
- **Ordering:** per-runbook_id DAG-compliant
- **Idempotency-Key:** sha256(runbook_id, step_id, action, target_hash)
- **Ack/Nack:** HTTP 202 / gRPC OK=ACK; NACK = 4xx/5xx with error_code
- **Timeouts/Retry:** ack<=5s; task_result<=deadline_s; retry per retry_policy (exp-backoff)
- **Side-Effects:** start task timer; register heartbeat expectation
- **HITL Token:** required if step flagged protected and no prior HITL approval recorded
- **Observability:** trace_id, mission_id, constraints.*, classification_label, provenance.attestation
- **Retention/TTL:** 1 year

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=WorkflowTaskDispatch@1.0 | json_schema_uri=uri://schema/workflow-task-dispatch-1.0.json | sha256= | producers=L3 | consumers=Containment-01, Evidence-01, Patch-01, IdP-01, EDR-Action-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: RunbookStatusEvent

(Started/TaskUpdate/AwaitingHITL/DeadlineBreach/Completed/RolledBack)

[Informative]

- **Producer(s):** L3
- **Topic/Path:** sec.runbook.status (Kafka/AMQP)
- **Schema/Format:** RunbookStatusEvent@1.0 (runbook_id, event_type, step_id?, action?, targets?, status, reason_code, progress_pct, remaining_deadline_s, links)
- **Classification:** C1–C2 (match runbook classification)

- **Delivery:** at-least-once
- **Ordering:** per-runbook_id
- **Idempotency-Key:** sha256(runbook_id, event_type, step_id?, ts_bucket_10s)
- **Ack/Nack:** broker ACK; retry/backoff on failure
- **Timeouts/Retry:** ack<=5s; exp-backoff<=7x
- **Side-Effects:** update IR portal timeline; notify subscribers (L2 Analytics, A1 Governance)
- **HITL Token:** none
- **Observability:** trace_id, mission_id, constraints.summary, classification_label, provenance.attestation
- **Retention/TTL:** 1 year

Schema Capsule (OC-2) [Normative]

Requirement Level: Required

Condition: Always

schema_id=RunbookStatusEvent@1.0 | json_schema_uri=uri://schema/runbook-status-1.0.json | sha256= | producers=L3 | consumers=IR-Portal-01, SIEM-01, Analytics-L2, Governance-A1 | accepts=1.0–1.x

Conformance: Normative.

OC-3: HITLApprovalRequest (gate or protected action) [Informative, optional]

- **Producer(s):** L3
- **Endpoint/Path:** Ticketing/ChatOps (REST webhook), or topic sec.runbook.hitl
- **Schema/Format:** HITLApprovalRequest@1.0 (runbook_id, step_id, action, risk_summary, blast_radius, evidence_refs, required_cosign, approvers, timeout_s)
- **Classification:** C2+ (may include sensitive context)
- **Delivery:** at-least-once
- **Ordering:** per-runbook_id
- **Idempotency-Key:** sha256(runbook_id, step_id, action)
- **Ack/Nack:** 2xx + approval_id; retry/backoff; escalate on timeout

- **Side-Effects:** pause DAG branch until approval or timeout; log decision outcome
- **HITL Token:** emitted by design (this is the approval request)
- **Observability:** trace_id, mission_id, policy_refs, classification_label, provenance.attestation
- **Retention/TTL:** 7 years (audit)

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When a step is gated (hitl_gate=*) or protected action lacks standing approval

schema_id=HITLApprovalRequest@1.0 | json_schema_uri=uri://schema/hitl-approval-1.0.json | sha256= | producers=L3 | consumers=Ticketing-01, ChatOps-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-4: RunbookCompletedEvent (final outcome) [Informative, optional]

- **Producer(s):** L3
- **Topic/Path:** sec.runbook.completed
- **Schema/Format:** RunbookCompletedEvent@1.0 (runbook_id, outcome={success|partial|failed|rolled_back}, total_duration_s, deadline_breached, summary, evidence_refs, followups)
- **Classification:** C1–C2
- **Delivery:** at-least-once
- **Ordering:** per-runbook_id
- **Idempotency-Key:** sha256(runbook_id, outcome, summary_hash)
- **Ack/Nack:** broker ACK; retry/backoff
- **Side-Effects:** open RCA task, notify DFIR/Knowledge L1, emit analytics hooks
- **HITL Token:** none
- **Observability:** trace_id, mission_id, classification_label, provenance.attestation
- **Retention/TTL:** 3 years

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: If consumers require a final summary separate from status stream
schema_id=RunbookCompletedEvent@1.0 | json_schema_uri=uri://schema/runbook-completed-1.0.json | sha256= | producers=L3 | consumers=DFIR-01, L1-KB-01, ExecPortal-01 | accepts=1.0–1.x

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, planning, dispatching, awaiting_task_acks, running, awaiting_hitl, monitoring_deadlines, rolling_back, contestation_workflow, completed, failed }
transition(idle -> planning) when DetectionEvent or ContainmentCommand received
transition(planning -> dispatching) when DAG built and constraints validated
transition(dispatching -> awaiting_task_acks) when tasks sent
transition(awaiting_task_acks -> running) when acks >= quorum for first stage
transition(running -> awaiting_hitl) when gate encountered (hitl_gate=)
transition(running -> monitoring_deadlines) when long-running steps active
transition(running -> rolling_back) on failure with rollback policy
transition(-> contestation_workflow) when dispute opened or co-sign missing
transition(running|awaiting_hitl|monitoring_deadlines -> completed) when DAG terminal nodes succeed
transition(* -> failed) on deadline breach without rollback or unrecoverable error

timeout(awaiting_task_acks, 5s) -> dispatching (retry<=3)
timeout(awaiting_hitl, gate_timeout_s) -> rolling_back or failed (per policy)
idempotency_key = sha256(runbook_id, step_id) for dispatches; sha256(runbook_id, event_type, step_id?, ts_bucket_10s) for status

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 WorkflowTaskDispatch	Required	Always	Executes response steps
OC-2 RunbookStatusEvent	Required	Always	End-to-end visibility and audit

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-3 HITLApprovalRequest	Conditionally Required	HITL gate or missing standing approval/co-sign	Safety and governance control
OC-4 RunbookCompletedEvent	Optional	Consumers need a terminal summary separate from status	Executive/DFIR summary & handoff

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: IR-4, IR-5, CP-2, SI-4 (+ internal runbook governance).
- **HITL required:** protected actions on CrownJewels; irreversible actions; actions with blast_radius > threshold; co-sign absent/expired.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; stakeholder_disagreement_score >= 0.5; deadline_breach_imminent = true.
- **Manual outside agent:** redefining playbook structure; modifying global constraints (e.g., max_concurrency).

SLOs and KPIs [Informative]

- DispatchAck_p95 <= 5 s
- TimeToKickoff_p95 (Detection→RunbookStarted) <= 20 s
- TimeToContainment_p95 (per playbook family) — set per org
- DeadlineBreachRate_30d <= 1 percent
- RollbackSuccessRate_30d >= 99 percent
- HITLResponse_p95 <= 15 min (business hours)

Outputs index [Informative]

[OC-1 WorkflowTaskDispatch], [OC-2 RunbookStatusEvent], [OC-3 HITLApprovalRequest], [OC-4 RunbookCompletedEvent]

Technical Implementation Details (L3) [Informative]

Model and training profile [Informative]

model_id=soar-orchestrator-text; temperature=0.0; max_tokens_out=600
prompt_pack_id=soar-orchestration-v1 (DAG grammar, constraints, cosign/HITL rules)
RAG: sources={playbooks, responder registry, constraint catalog, governance A1}
fine_tuning/adapters: none initially; eval on constraint fidelity and zero deviation from DAG rules
guardrails: enforce sequence/parallel_group/deadline; **require** A1 PolicyCoSign for protected steps; scoped tokens for each responder API

Memory and state [Informative]

working_memory.max_tokens=3k; eviction=recency_then_importance
episodic_memory: per mission_id runbook journal; ttl=365d
semantic_memory: namespaces=["playbooks","responders","constraints"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced runbook ledger; snapshot at stage boundaries
consistency: exactly-once (dispatch per step); at-least-once (status/events)
idempotency: as per Output Contracts

Decision and routing logic [Informative]

schedulable = validate(DAG, constraints, approvals, cosign_ok)
parallelizable = group_by(parallel_group) subject to max_concurrency
deadline_allocation(step) = min(step_budget, global_deadline_remaining / remaining_critical_path_length)
rollback_if failure and rollback_policy.on_fail contains remedial step
complete_if all terminal nodes Succeeded and no pending gates

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens for DAG expansion, adversarial constraint mutations, jailbreak]
thresholds: eval_pass_rate >= 99.5 percent → else auto_HITL for all protected steps
red_team_cycle: monthly simulation (command injection, replay/idempotency abuse)
rollback_policy: if eval_drop >= 1.5 percentage points for 48 h → revert
prompt_pack_id/model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

decision_rationale_template: selected playbook, DAG, constraints, co-sign checks, approvals, failure reasons
UI/API: show classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL timeline per runbook_id; retention per classification/legal_hold

Incident Response Integration [Informative]

post-completion: emit RunbookCompletedEvent; link to RCA creation; notify Knowledge L1 for pattern extraction

Stakeholder Feedback Loop [Informative]

collect feedback via Ticketing/ChatOps; aggregate into FeedbackIngestionEvent (if used at program level), gated by governance review

Data Sovereignty and Legal Hold [Informative]

respect region tags on dispatch targets; legal_hold=true → freeze runbook ledger and artifacts; restrict fan-out of events

Interfaces (links only) [Informative]

Consumes: DetectionEvent; ContainmentCommand
Produces: OC-1, OC-2, OC-3 (conditional), OC-4 (optional)

Safety and abuse prevention [Informative]

kill_switch: disable protected dispatches if co-sign verification fails; rate-limit per mission_id; deny-step if args outside allowlisted patterns

Testing and validation [Informative]

contract tests for OC-1..OC-4; offline replay of historical incidents; chaos testing for deadline/rollback; drift checks and rollback

Deployment and lifecycle [Informative]

scale by active runbooks; canary new constraint packs; SBOM + attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-61 Rev. 2 (IR); NIST SP 800-137 (ISCM); NIST SP 800-53 Rev. 5; NIST CSF 2.0; ISO/IEC 27002:2022; MITRE ATT&CK/D3FEND; CIS v8

MCP-Native Protocol Specification (L3) [Normative]

- **Native Protocol(s) Consumed:**
 - DetectionEvent (Kafka/AMQP or REST) — detector outputs from SIEM/EDR/IDS
 - ContainmentCommand (REST/Kafka) — operator/policy engine directive to execute a runbook
- **Native Protocol(s) Produced:**
 - WorkflowTaskDispatch via REST/gRPC to responder agents
 - Kafka/AMQP events:
RunbookStarted/WorkflowTaskDispatched/RunbookStatus/RunbookCompleted
 - Ticketing/ChatOps updates (optional)
- **MCP Context Fields:**
 - **Required:** mission_id; role="SOAROrchestrationAgent"; intent="orchestrate"; constraints (sequence, parallel_group, max_concurrency, deadline, hitl_gate); provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** policy_refs; classification (C1–C3); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold
- **Enforcement Note:** PEPs MUST enforce co-sign verification for protected actions, declared orchestration constraints, provenance checks, and classification-aware distribution.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** native and MCP-wrapped examples above are authoritative.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is [Normative] and, together with each **Schema Capsule**, defines testable requirements.

L4. Data Curation Agent

Agent Blueprint [Informative]

Purpose: Prepare high-quality datasets for security model training/evaluation by ingesting telemetry and labels, applying privacy-preserving redaction, balancing classes, and emitting versioned **CuratedDataset** artifacts with manifests.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Telemetry (OTel logs/metrics/traces; JSON/JSONL via REST/Kafka/OTLP):** event body, resource attributes, attributes map (may contain PII/secrets), timestamps.
- **Labels (Annotation/LabelStore REST):** weak/strong labels, annotator metadata, rationale, schema version, task metadata.

Model training / knowledge (what the LLM relies on):

- Curation prompt-pack: redaction operators, k-anonymity/l-diversity rules, sampling/stratification rubric, leakage detection patterns, manifest schema.
- RAG sources: redaction policy registry, PII/secret detectors reference set, label-trust weights, dataset catalog, ATT&CK tags for stratification. Evidence is referenced via evidence_refs (no raw regulated evidence in training).
- Guardrails: write scope limited to curated buckets and manifest registry; deny writes to raw telemetry locations; constrained tools for object store and label APIs.

Decisions it makes (deterministic + model-assisted):

- **Redaction & de-identification:** choose operators per field policy (hash/tokenize/mask/generalize); verify k-anonymity $\geq$ threshold and l-diversity for sensitive quasi-identifiers.
- **Label curation:** weight labels by trust; resolve conflicts; drop low-confidence labels if required.
- **Balancing & stratification:** compute per-class sampling rates; enforce train/val/test splits with leakage prevention (group by asset/user/incident).
- **Packaging & versioning:** produce immutable dataset version with manifest, schema, lineage, and policy digest.

Routing / where outputs go:

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- **CuratedDataset** → object store path s3://ml/datasets/<dataset_id>/v<N>; manifest pushed to registry (REST/GraphQL).
- **DataQualityReport** (optional) → REST or Kafka for consumers (Training/Eval/Analytics).
- **LeakageAlert** (conditional) → event bus + Ticketing when PII/secret leakage or policy violations detected.

Automation scope vs. manual/HITL:

- Fully automated: ingest, redact, stratify/split, package, publish, DQ checks.
- **HITL required:** changes to redaction policy or thresholds; overrides of min_k_anonymity; exporting C2/C3 data across regions; dataset deprecation requests.
- Manual outside agent: definition of new label schemas; legal approvals for exceptional data use.

Security Domain: Security Program Enablement

Inputs (native protocols consumed) [Informative]

1. **Telemetry (OpenTelemetry logs/metrics/traces export; JSON/JSONL over REST/Kafka/OTLP)** — raw security-relevant telemetry
2. **Labels (Annotation/LabelStore REST)** — weak/strong labels, spans, task metadata

Example: Consumed Protocol — Telemetry (OTel export) [Informative]

Native payload

```
{
  "timestamp": "2025-08-15T14:03:12Z",
  "resource": {"service.name": "waf-gateway", "service.namespace": "edge"},
  "attributes": {
    "event_type": "waf_block",
    "client_ip": "198.51.100.44",
    "user_email": "april.ng@example.com",
    "http_target": "/../etc/passwd",
```

```

    "waf_rule_id": "SI-4-002",
    "response_code": 403
  },
  "body": "Blocked path traversal attempt"
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-l4-curate-1111-2222-3333-4444",
    "thread_id": "uuid-otel-waf-2025-08-15T14:03:12Z",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "DataCurationAgent",
    "intent": "curate",
    "policy_refs": ["SI-19", "AU-9", "SC-13"],
    "constraints": ["redact:pii,secrets", "min_k_anonymity:5", "retain_days:365"],
    "decision_basis": {
      "evidence_refs": ["uri://otel/logs/waf-gateway/2025-08-15T14:03:12Z"],
      "redaction_map": {
        "user_email": "hash(email)|tokenize",
        "client_ip": "mask_ipv4(/24)"
      },
    },
    "sampling_policy": "stratified by event_type with minority class upweight",
    "confidence": 0.98,
    "explanation_ref": "uri://docs/data-curation/redaction-and-sampling-v1"
  },
  "provenance": {

```

```

    "producer_spiffe": "spiffe://enterprise/program/data-curation-agent",
    "signing_kid": "kid-otel-l4-01",
    "attestation_ref": "uri://slsa/attestations/data-curation@sha256:otel01"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... as above ... }
}

```

Example: Consumed Protocol — Labels (Annotation/LabelStore) [Informative]
Native payload

```

{
  "label_batch_id": "LBL-2025-08-15-0007",
  "task_type": "binary_classification",
  "schema_version": "1.1",
  "labels": [
    {
      "source_ref": "uri://otel/logs/waf-gateway/2025-08-15T14:03:12Z",
      "label": "malicious",
      "rationale": "path traversal signature matched + 403 block",
      "annotator": "sec.analyst.17",
      "method": "human_review"
    },
    {
      "source_ref": "uri://otel/logs/waf-gateway/2025-08-15T14:05:08Z",
      "label": "benign",
      "rationale": "normal asset fetch",

```

```

    "annotator": "auto_weak_labeler",
    "method": "heuristic"
  }
],
"created": "2025-08-15T14:10:00Z"
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-l4-curate-5555-6666-7777-8888",
    "thread_id": "uuid-labels-LBL-2025-08-15-0007",
    "task_id": "uuid-9911-8822-7733-6644",
    "role": "DataCurationAgent",
    "intent": "curate",
    "policy_refs": ["SI-19", "AR-4"],
    "constraints": ["redact:pii", "retain_days:365"],
    "decision_basis": {
      "evidence_refs": ["uri://labels/batches/LBL-2025-08-15-0007"],
      "label_confidence_mapping": {"human_review": 0.95, "heuristic": 0.75},
      "confidence": 0.96,
      "explanation_ref": "uri://docs/data-curation/label-trust-and-weighting"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/program/data-curation-agent",
      "signing_kid": "kid-labels-l4-02",
      "attestation_ref": "uri://slsa/attestations/data-curation@sha256:labels02"
    }
  }
}

```

```

    },
    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": { ... as above ... }
}

```

Outputs (native) [Informative]

- **CuratedDataset** objects with manifest (manifest.json) and checksums.
- **DataQualityReport** with profiling, coverage, leakage checks (optional).

MCP context (required) [Informative]

mission_id; role="DataCurationAgent"; intent="curate"; constraints (e.g., redact:..., min_k_anonymity:..., retain_days:...); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

policy_refs; classification (C1–C3); decision_basis (evidence_refs, redaction_map, sampling_policy); legal_hold

Enforcement note [Informative]

PEPs must verify provenance.attestation; enforce **redaction** completion and **min_k_anonymity** on CuratedDataset; block export across regions unless data_locality and classification policy allow.

NIST SP 800-160v2 linkage [Informative]

Maintain & Evolve — disciplined knowledge management and privacy-preserving engineering.

Automation feasibility [Informative]

High (ingest, redact, stratify, package are automatable; SME review for label policy updates).

Output Contracts (merged) [Informative]

OC-1: CuratedDatasetPublish [Informative]

- **Producer(s)**: L4

- **Endpoint/Path:** s3://ml/datasets/<dataset_id>/v<N> (objects) + POST /datasets/manifest (registry)
- **Schema/Format:** CuratedDatasetManifest@1.1 (dataset_id, version, slices, schema_refs, redaction_digest, sampling_digest, lineage, evidence_refs, checksums, size, row_count, splits)
- **Classification:** C1 by default; C2/C3 if derived from regulated incidents (must reflect after-redaction class)
- **Delivery:** exactly-once per (dataset_id, version)
- **Ordering:** per-dataset_id
- **Idempotency-Key:** sha256(dataset_id, version)
- **Ack/Nack:** registry 201 or update 200; NACK on 4xx/5xx
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; halt publish on manifest validation failure
- **Side-Effects:** update dataset catalog; emit lineage record; notify training orchestrator
- **HITL Token:** required when min_k_anonymity is lowered or when C2/C3 export-to-nonhome-region is requested
- **Observability:** trace_id, mission_id, constraints, classification_label, provenance.attestation
- **Retention/TTL:** retain_days from constraints (legal_hold overrides)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=CuratedDatasetManifest@1.1 | json_schema_uri=uri://schema/curated-dataset-manifest-1.1.json | sha256= | producers=L4 | consumers=Train-01, Eval-01, Registry-01 | accepts=1.0–1.1 (1.0 EOL 2026-12-31)

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: DataQualityReport [Informative]

- **Producer(s):** L4
- **Endpoint/Path:** POST /datasets/dq-report or topic sec.ml.dq

- **Schema/Format:** DataQualityReport@1.0 (dataset_id, version, profile_stats, class_balance, leakage_checks, k_anonymity, l_diversity, missingness, label_agreement, warnings)
- **Classification:** C1 (aggregates); C2 if includes sensitive slice names
- **Delivery:** at-least-once
- **Ordering:** per-dataset_id
- **Idempotency-Key:** sha256(dataset_id, version, report_kind)
- **Ack/Nack:** 2xx/ACK; retry/backoff on failure
- **Timeouts/Retry:** ack<=30s; exp-backoff<=7x
- **Side-Effects:** gate training job if fail; open ticket on leakage or policy violation
- **HITL Token:** required to override gating failures
- **Observability:** trace_id, mission_id, policy_refs, constraints, provenance.attestation
- **Retention/TTL:** 3 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When DQ gating is enabled or any gating rule is configured

schema_id=DataQualityReport@1.0 | json_schema_uri=uri://schema/data-quality-report-1.0.json | sha256= | producers=L4 | consumers=Train-01, Eval-01, Governance-A1 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: LeakageAlert (PII/Secret/Policy Violation) [Informative]

- **Producer(s):** L4
- **Topic/Path:** sec.ml.leakage (Kafka/AMQP) or POST /datasets/leakage-alert
- **Schema/Format:** LeakageAlert@1.0 (dataset_id, version, violation_kind, field, evidence_ref, sample_count, severity, recommended_action)
- **Classification:** C2+
- **Delivery:** at-least-once
- **Ordering:** per-dataset_id

- **Idempotency-Key:** sha256(dataset_id, version, violation_kind, field)
- **Ack/Nack:** ACK/2xx; retry/backoff; escalate on repeated failure
- **Side-Effects:** block publish; open governance ticket; notify DPO/legal if AR-* controls apply
- **HITL Token:** required to unblock publish or approve exception
- **Observability:** trace_id, mission_id, constraints, classification_label, provenance.attestation
- **Retention/TTL:** 7 years (audit)

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When leakage checks detect violations or when policy mandates proactive alerting

schema_id=LeakageAlert@1.0 | json_schema_uri=uri://schema/leakage-alert-1.0.json | sha256= | producers=L4 | consumers=Governance-A1, DPO-Portal-01, Train-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

State machine (concise) [Informative]

states = { idle, ingesting_telemetry, ingesting_labels, redacting, deduplicating, stratifying, splitting, packaging, publishing, emitting_dq, contestation_workflow, failed, closed }

transition(idle -> ingesting_telemetry) when OTel batch arrives

transition(ingesting_telemetry -> ingesting_labels) when label window opens

transition(ingesting_labels -> redacting) when label join succeeds

transition(redacting -> deduplicating) when redaction pass == true

transition(deduplicating -> stratifying) when uniques consolidated

transition(stratifying -> splitting) when class balance within tolerance

transition(splitting -> packaging) when leakage_prevention checks pass

transition(packaging -> publishing) when manifest validated

transition(publishing -> emitting_dq) when publish ACKed

transition(* -> contestation_workflow) on dispute, policy override, or leakage violation

transition(* -> failed) on validation error, timeout, or policy breach

timeout(publishing, 60s) -> failed; retry <= 5 with exp backoff

idempotency_key = sha256(dataset_id, version) for publish; sha256(dataset_id, version, report_kind) for DQ

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 CuratedDatasetPublish	Required	Always	Source of truth for training/eval
OC-2 DataQualityReport	Conditionally Required	DQ gating enabled or rules configured	Prevents low-quality or leaky datasets
OC-3 LeakageAlert	Conditionally Required	Leakage check detects PII/secret or policy violations	Privacy compliance and risk mitigation

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** SI-19 (De-identification), AU-9, SC-13, AR-* privacy controls, internal data-locality policy.
- **HITL required:** lowering min_k_anonymity; exporting C2/C3 outside region; overriding LeakageAlert; modifying redaction operators.
- **Automatic HITL escalation triggers:** k_anonymity < threshold; l_diversity < threshold; leakage_detected = true; legal_hold=true with purge attempted.

SLOs and KPIs [Informative]

- DatasetPublishAck_p95 <= 60 s
- DQPassRate_30d >= 99 percent
- LeakageIncidents_30d == 0 (goal)
- ClassBalanceTolerance <= 5 percent delta from target per split

- **k-anonymity:**
 - `quasi_identifiers = {masked_ip_block, service.namespace, event_type, time_bucket}`
 - `k = min group_count over quasi_identifiers groups`
 - require `k >= min_k_anonymity` (from constraints)
- **l-diversity:** for sensitive attribute label, require at least `l` distinct values per quasi-identifier group if configured.
- **Sampling and balancing:**
 - `target_ratio(class) = min(1.0, cap / observed_ratio)` with cap set by policy
 - `stratified_sample` by `event_type`, `environment`, `ttp tags`
 - `train/val/test` split by grouping key = `hash(asset_id||user_id||incident_id)` to prevent leakage
- **Publish rule:** `publish_if redaction_pass && k >= threshold && leakage_detected == false && dq_checks_pass`

Model Risk Management [Informative]

`continuous_validation`: daily; `eval_suite`=[goldens for PII/secret, adversarial strings, schema fuzz];

`thresholds`: `redaction_precision >= 0.995` and `redaction_recall >= 0.99` → else `auto_HITL`;

`red_team_cycle`: monthly secret/PII injection tests;

`rollback_policy`: on `eval_drop >= 1.5` percentage points for 48 h → revert `prompt_pack_id/model_id`; notify owners.

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

`decision_rationale_template`: `redaction_map`, `k` value, `l-diversity` result, sampling policy, lineage;

UI/API: expose `classification_label`, `provenance.attestation`, `decision_rationale_url`;

`audit_log_format`: JSONL with stable field order; `legal_hold` pins retention.

Incident Response Integration [Informative]

on `LeakageAlert`, block training pipeline; open Governance A1 ticket; attach `evidence_refs` and offending sample summaries.

Change Impact Assessment [Informative]

estimate delta_on_model = f(sample_size_change, class_balance_shift, rarity_weight);
require review if delta_on_model >= threshold.

Stakeholder Feedback Loop [Informative]

collect SME feedback on mislabeled or over-redacted fields; update redaction policy after governance review (no auto-training on regulated evidence).

Data Sovereignty and Legal Hold [Informative]

enforce region tags; legal_hold=true locks dataset version; export only per policy and classification.

Interfaces (links only) [Informative]

Consumes: Telemetry (OTel); Labels (Annotation/LabelStore)

Produces: OC-1 CuratedDatasetPublish; OC-2 DataQualityReport; OC-3 LeakageAlert

Safety and abuse prevention [Informative]

kill_switch on provenance or schema failure; rate limits per mission_id; deny publish if manifest hash mismatch; secret scanning on artifacts.

Testing and validation [Informative]

contract tests for OC-1..OC-3; offline replay with seeded PII/secrets; verify k-anonymity and splits; drift checks and rollback.

Deployment and lifecycle [Informative]

scale by ingest volume; canary redaction policies; SBOM + attestations; sign all outputs.

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (SI-19, AU-9, SC-13, AR-*); NIST SP 800-61 Rev. 2; NIST SP 800-137; NIST CSF 2.0; ISO/IEC 27002:2022; MITRE ATT&CK/D3FEND; CIS v8

MCP-Native Protocol Specification (L4) [Normative]

- **Native Protocol(s) Consumed:**

- Telemetry (OTel logs/metrics/traces; JSON/JSONL via REST/Kafka/OTLP)
- Labels (Annotation/LabelStore REST; JSON weak/strong labels)

- **Native Protocol(s) Produced:**

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- CuratedDataset objects (object store + manifest registry)
- DataQualityReport (optional)
- LeakageAlert (conditional)
- **MCP Context Fields:**
 - **Required:** mission_id; role="DataCurationAgent"; intent="curate"; constraints (redact:..., min_k_anonymity:..., retain_days:...); provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** policy_refs; classification (C1–C3); decision_basis (evidence_refs, redaction_map, sampling_policy); legal_hold
- **Enforcement Note:** PEPs must verify redaction completion, k-anonymity threshold, provenance, classification, and region policy before allowing dataset consumption or export.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL.
- **Example payloads:** native and MCP-wrapped examples above are authoritative.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

L5. AI Validation Agent

Agent Blueprint [Informative]

Purpose: Validate security AI models for performance, robustness, and bias; confirm policy conformance and provenance before promotion. Emits an auditable

ValidationReport and enforces approval constraints.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Model Artifacts (Model Registry / OCI / Artifact Store):** model binary and container image refs, lineage, signatures, model card, SBOM, owners.
- **Validation Sets (CuratedDataset manifests):** versioned dataset URIs, schema, sensitive attribute lists, distribution summaries, redaction status.

Model training / knowledge (what the LLM relies on):

- Validation prompt-pack: metric definitions, bias and robustness test batteries, calibration and drift checks, gating policy rules, reviewer note templates.
- RAG sources: schema registry, formula registry, fairness policy, robustness policy, model registry metadata, dataset catalog. Evidence is cited via evidence_refs.
- Guardrails: read-only access to models and datasets; write scope limited to ValidationReport and gate decision endpoints; enforced constraints (no_prod_deploy_until, bias_thresholds, robustness).

Decisions it makes (deterministic + model-assisted):

- **Verify provenance:** signature and attestation checks (cosign, in-toto), lineage consistency with training_data_hash and CuratedDataset manifest.
- **Compute metrics:** accuracy, ROC AUC, PR AUC, confusion matrix, calibration error; segmentation by slices (env, control family, time).
- **Assess fairness:** statistical parity difference, equalized odds difference, positive predictive value difference; pass or fail vs. bias_thresholds.
- **Assess robustness:** attack success rate under configured adversarial budget; degradation under noise or shift; pass or fail vs. robustness thresholds.
- **Gate decision:** allow, allow_with_conditions, or deny; determine required approvers and HITL when policy thresholds or high risk are detected.

Routing / where outputs go:

- **ValidationReport** → REST/GraphQL (registry), Kafka topic for subscribers (Governance A1, MLOps, Exec portal).
- **PromotionGateDecision** (conditional) → CI/CD gate, deployment controller, governance workflow.
- **BiasAlert** (conditional) → DPO/Compliance queue if fairness thresholds breached.
- **Tickets/alerts** → open issues for failures or missing provenance.

Automation scope vs. manual/HITL:

- Fully automated: artifact fetch, dataset fetch, provenance checks, metric computation, bias and robustness evaluation, report generation and publication.

- **HITL required:** override of thresholds; promotion when any Required check fails; deployment before no_prod_deploy_until; models affecting CrownJewels workflows.
- Manual outside agent: setting org policy thresholds; selecting new test batteries; risk acceptance signoffs.

Security Domain: Security Program Enablement

Inputs (native protocols consumed) [Informative]

1. **Model Artifacts (Model Registry / OCI / Artifact Store via REST)** — model binary and metadata, lineage, signatures
2. **Validation Sets (CuratedDataset manifests via REST/Object Storage)** — versioned datasets and schemas

Example: Consumed Protocol — Model Artifacts [Informative]

Native payload

```
{
  "model_id": "mdl-detector-waf-bert",
  "version": "3.4.2",
  "framework": "onnx",
  "artifact_uri": "s3://ml/artifacts/mdl-detector-waf-bert/3.4.2/model.onnx",
  "training_data_hash": "sha256:9c41...e1",
  "lineage": {
    "parent_model_id": "mdl-detector-waf-bert",
    "parent_version": "3.3.0",
    "curation_job_id": "CUR-2025-08-10-001"
  },
  "container_image": {
    "image_ref": "registry.example.com/ml/waf-detector:3.4.2",
    "digest": "sha256:77a1...de"
  },
}
```

```

"signatures": [
  {"type": "cosign", "signer": "sec-ml-ci", "sig_ref": "oci://.../sig@sha256:abcd"}
],
"model_card_uri": "s3://ml/cards/mdl-detector-waf-bert/3.4.2/model-card.md",
"sbom_uri": "s3://ml/sbom/mdl-detector-waf-bert/3.4.2/syft.json",
"created_at": "2025-08-15T12:40:00Z",
"owners": ["ml.platform", "sec.ml"]
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-l5-validate-1111-2222-3333-4444",
    "thread_id": "uuid-model-mdl-detector-waf-bert-3.4.2",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "AIValidationAgent",
    "intent": "assess",
    "policy_refs": ["SA-11", "SA-12", "SA-15", "PM-5", "NIST-AI-RMF"],
    "constraints": [
      "approval_required:sec-ml-approver",
      "no_prod_deploy_until:2025-08-20",
      "bias_thresholds:spd<=0.1,eod<=0.1",
      "robustness:adv_eps<=0.03"
    ],
    "decision_basis": {
      "evidence_refs": [
        "uri://registry/models/mdl-detector-waf-bert/versions/3.4.2",

```

```

    "s3://ml/cards/mdl-detector-waf-bert/3.4.2/model-card.md",
    "s3://ml/sbom/mdl-detector-waf-bert/3.4.2/syft.json"
  ],
  "formulas": [
    "Accuracy = correct_predictions / total_predictions",
    "ROC_AUC = trapezoidal_integral_of_TPR_over_FPR",
    "CalibrationError =
mean_absolute_diff_between_predicted_prob_and_empirical_freq_over_bins"
  ],
  "confidence": 0.96,
  "explanation_ref": "uri://kb/ml/validation/waf-detector-eval-checklist"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/program/ai-validation-agent",
  "signing_kid": "kid-model-l5-01",
  "attestation_ref": "uri://slsa/attestations/ai-validation@sha256:model01"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { /* same as Native Payload above */ }
}

```

Example: Consumed Protocol — Validation Sets (CuratedDataset manifest)

[Informative]

Native payload

```

{
  "dataset_id": "waf-blocks-2025w33",
  "version": 4,

```

```

"uri": "s3://ml/datasets/waf-blocks-2025w33/v4/",
"splits": {"train": 0, "valid": 0, "test": 250000},
"schema": {
  "features": [
    {"name": "http_target", "type": "string"},
    {"name": "client_asn", "type": "string"},
    {"name": "waf_rule_id", "type": "string"},
    {"name": "hour_of_day", "type": "int"}
  ],
  "label": {"name": "is_malicious", "type": "boolean"},
  "sensitive_attrs": [
    {"name": "geo_region", "values": ["NA", "EU", "APAC", "LATAM"]},
    {"name": "device_type", "values": ["desktop", "mobile"]}
  ]
},
"distribution": {
  "label_positive_rate": 0.12,
  "geo_region_counts": {"NA": 120000, "EU": 60000, "APAC": 50000, "LATAM": 20000}
},
"redaction": {"pii": "tokenized", "ip": "masked-/24"},
"created_at": "2025-08-14T21:00:00Z",
"source_refs": ["uri://otel/logs/waf-gateway/*", "uri://labels/batches/LBL-2025-08-15-0007"]
}
MCP-wrapped payload
{
  "mcp_context": {

```

```

"mcp_version": "0.9",
"mission_id": "uuid-l5-validate-5555-6666-7777-8888",
"thread_id": "uuid-dataset-waf-blocks-2025w33-v4",
"task_id": "uuid-9911-8822-7733-6644",
"role": "AIValidationAgent",
"intent": "assess",
"policy_refs": ["SI-19", "AR-4", "PM-5", "NIST-AI-RMF"],
"constraints": [
  "bias_thresholds:spd<=0.1,eod<=0.1,pprev_diff<=0.1",
  "no_leakage:true",
  "dataset_redaction:required"
],
"decision_basis": {
  "evidence_refs": [
    "s3://ml/datasets/waf-blocks-2025w33/v4/manifest.json",
    "uri://labels/batches/LBL-2025-08-15-0007"
  ],
  "formulas": [
    "SPD = P(y_hat=1 | A=a1) - P(y_hat=1 | A=a2)",
    "EOD_TPR = TPR(a1) - TPR(a2); EOD_FPR = FPR(a1) - FPR(a2)",
    "PPRevDiff = P(y=1 | A=a1) - P(y=1 | A=a2)",
    "LeakFlag = 1 if mutual_information(X_i, y) >= tau_leak else 0"
  ],
  "confidence": 0.94,
  "explanation_ref": "uri://kb/ml/fairness-and-leakage-tests"
},
"provenance": {

```

```

    "producer_spiffe": "spiffe://enterprise/program/ai-validation-agent",
    "signing_kid": "kid-dataset-I5-02",
    "attestation_ref": "uri://slsa/attestations/ai-validation@sha256:dataset02"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { /* same as Native Payload above */ }
}

```

Outputs (native) [Informative]

- **ValidationReport** (REST/GraphQL/Kafka) with metrics, bias analysis, robustness checks, and sign-offs.

MCP context (required) [Informative]

mission_id; role="AIValidationAgent"; intent="assess"; provenance (SPIFFE ID, signing KID, attestation); constraints (approval_required, no_prod_deploy_until, bias_thresholds, robustness); policy_refs

MCP context (optional) [Informative]

decision_basis (evidence_refs, formulas, confidence, explanation_ref); classification (C2–C3 per sensitivity); legal_hold

Enforcement note [Informative]

PEPs and deployment controllers **MUST** block promotion unless ValidationReport status is allow or allow_with_conditions, required approvals are satisfied, and no_prod_deploy_until is in the past; fairness and robustness threshold failures require HITL override with recorded rationale.

NIST SP 800-160v2 linkage [Informative]

Evaluate & Maintain — disciplined V&V to ensure resilient, trustworthy AI; aligns with **NIST AI RMF** and **NIST SP 800-53 SA-11/SA-12/SA-15**.

Automation feasibility [Informative]

High (evaluation is automatable; promotion gated by approvals and HITL).

Output Contracts (merged) [Informative]

OC-1: ValidationReport [Informative]

- **Producer(s):** L5
- **Endpoint/Path:** POST /validation/report or topic sec.ml.validation.report
- **Schema/Format:** ValidationReport@1.1 (model_id, version, dataset_id, metrics, calibration, bias_results, robustness_results, provenance_checks, status, required_approvals, conditions, evidence_refs)
- **Classification:** C2 (contains model and dataset details)
- **Delivery:** exactly-once per (model_id, version, dataset_id)
- **Ordering:** per-model_id
- **Idempotency-Key:** sha256(model_id, version, dataset_id)
- **Ack/Nack:** 201 or broker ACK; NACK on schema/provenance error
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; fail closed on repeated NACK
- **Side-Effects:** update registry with validation status; notify approvers; link to model card
- **HITL Token:** required when any Required check fails or when status is allow_with_conditions
- **Observability:** trace_id, mission_id, decision_basis.formulas, evidence_refs, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=ValidationReport@1.1 | json_schema_uri=uri://schema/validation-report-1.1.json | sha256= | producers=L5 | consumers=ModelRegistry-01, DeployGate-01, Governance-A1, ExecPortal-01 | accepts=1.0–1.1

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: PromotionGateDecision [Informative]

- **Producer(s):** L5

- **Endpoint/Path:** POST /deploy/gate-decision or topic sec.ml.deploy.gate
- **Schema/Format:** PromotionGateDecision@1.0 (model_id, version, dataset_id, status={allow|allow_with_conditions|deny}, conditions, expires_at, required_approvals, rationale_ref)
- **Classification:** C2
- **Delivery:** exactly-once per (model_id, version, dataset_id)
- **Ordering:** per-model_id
- **Idempotency-Key:** sha256(model_id, version, dataset_id, status, expires_at_floor_1h)
- **Ack/Nack:** 2xx or ACK; retry/backoff on failure
- **Timeouts/Retry:** ack<=30s; exp-backoff<=7x
- **Side-Effects:** block or unblock deployment; open approval tasks; set no_prod_deploy_until if deny
- **HITL Token:** required when overriding deny or adding exceptions
- **Observability:** trace_id, mission_id, policy_refs, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When integrated with CI/CD or deployment gates

schema_id=PromotionGateDecision@1.0 | json_schema_uri=uri://schema/promotion-gate-decision-1.0.json | sha256= | producers=L5 | consumers=DeployGate-01, CI-01, Governance-A1 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: BiasAlert [Informative]

- **Producer(s):** L5
- **Topic/Path:** sec.ml.validation.bias-alert
- **Schema/Format:** BiasAlert@1.0 (model_id, version, dataset_id, sensitive_attr, metric, value, threshold, severity, recommended_action, evidence_refs)
- **Classification:** C2+

- **Delivery:** at-least-once
- **Ordering:** per-model_id
- **Idempotency-Key:** sha256(model_id, version, dataset_id, sensitive_attr, metric)
- **Ack/Nack:** broker ACK; retry/backoff on failure
- **Timeouts/Retry:** ack<=10s; exp-backoff<=7x
- **Side-Effects:** notify DPO/compliance; pause gate until review
- **HITL Token:** required to accept risk or adjust threshold
- **Observability:** trace_id, mission_id, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When fairness thresholds are configured and breached

schema_id=BiasAlert@1.0 | json_schema_uri=uri://schema/bias-alert-1.0.json | sha256= | producers=L5 | consumers=DPO-01, Governance-A1, DeployGate-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-4: RobustnessEvaluation [Informative]

- **Producer(s):** L5
- **Topic/Path:** sec.ml.validation.robustness or POST /validation/robustness
- **Schema/Format:** RobustnessEvaluation@1.0 (model_id, version, dataset_id, attack_family, eps_or_budget, attack_success_rate, delta_accuracy, notes, evidence_refs)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-model_id
- **Idempotency-Key:** sha256(model_id, version, dataset_id, attack_family, eps_or_budget)
- **Ack/Nack:** ACK/2xx; retry/backoff
- **Side-Effects:** update robustness dashboard; may block gate if configured

- **HITL Token:** required to waive robustness failures on critical assets
- **Observability:** trace_id, mission_id, classification_label, provenance.attestation
- **Retention/TTL:** 3 years

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When robustness test battery is enabled

schema_id=RobustnessEvaluation@1.0 | json_schema_uri=uri://schema/robustness-evaluation-1.0.json | sha256= | producers=L5 | consumers=DeployGate-01, Governance-A1 | accepts=1.0–1.x

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, fetching_artifacts, fetching_datasets, verifying_provenance, running_eval, computing_bias, computing_robustness, compiling_report, gating, publishing, contestation_workflow, failed, closed }

transition(idle -> fetching_artifacts) when model version registered

transition(fetching_artifacts -> fetching_datasets) when artifacts pulled and hashed

transition(fetching_datasets -> verifying_provenance) when manifests fetched

transition(verifying_provenance -> running_eval) when signatures and lineage verified

transition(running_eval -> computing_bias) when base metrics computed

transition(computing_bias -> computing_robustness) when fairness finished and robustness required

transition(* -> compiling_report) when all checks done

transition(compiling_report -> gating) when report generated

transition(gating -> publishing) when decision determined

transition(* -> contestation_workflow) when dispute or override request opened

transition(* -> failed) on signature failure, leakage, schema mismatch, or timeout

timeout(publishing, 60s) -> failed; retry <= 5 with exp backoff

idempotency_key = sha256(model_id, version, dataset_id) for report; sha256(model_id, version, dataset_id, decision_bucket_1h) for gate

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 ValidationReport	Required	Always	Auditable model validation and provenance
OC-2 PromotionGateDecision	Conditionally Required	CI/CD or deployment gates integrated	Enforces promotion policy
OC-3 BiasAlert	Conditionally Required	Fairness thresholds configured and breached	Compliance and risk governance
OC-4 RobustnessEvaluation	Optional	Robustness battery enabled	Visibility into adversarial resilience

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: SA-11, SA-12, SA-15, PM-5; NIST AI RMF; SI-19 and AR-* where datasets include sensitive attributes.
- **HITL required:** threshold overrides; promotion when any Required check fails; deployment prior to no_prod_deploy_until; models tied to CrownJewels.
- **Automatic HITL escalation triggers:** bias_breach = true; robustness_failure = true; provenance_signature_invalid = true; model_card_incomplete = true.

SLOs and KPIs [Informative]

- ReportPublishAck_p95 <= 60 s
- GateDecisionLatency_p95 <= 30 s
- ProvenanceVerificationPassRate_30d >= 99.9 percent

- `ReproducibilityRate_30d` $\geq$ 99 percent (rerun yields metric deltas within tolerance)
- `FalseAllowRate_90d` $\leq$ 0.5 percent; `FalseDenyRate_90d` $\leq$ 2 percent

Outputs index [Informative]

[OC-1 ValidationReport], [OC-2 PromotionGateDecision], [OC-3 BiasAlert], [OC-4 RobustnessEvaluation]

Technical Implementation Details (L5) [Informative]

Model and training profile [Informative]

`model_id`=ai-validation-text; `temperature`=0.0; `max_tokens_out`=900
`prompt_pack_id`=validation-v1 (metric defs, fairness, robustness, gating policy)
 RAG: `sources`={schema registry, formula registry, fairness policy, robustness policy, model registry, dataset catalog}; `max_docs`=16; `min_similarity`=0.78; `citations required`
`fine_tuning/adapters`: none initially; eval on formula fidelity and policy adherence
`guardrails`: enforce constraints for `bias_thresholds` and `robustness`; deny gate overrides without HITL token

Memory and state [Informative]

`working_memory.max_tokens`=4k; `eviction`=recency_then_importance
`episodic_memory`: per `mission_id` validation journal; `ttl`=365d
`semantic_memory`:
`namespaces`=["metrics", "fairness", "robustness", "models", "datasets"]; `embeddings`=text-embedding-sec-v1; `k`=10
`durable_state_store`: event-sourced with snapshots on publish
`consistency`: exactly-once (ValidationReport); at-least-once (alerts)
`idempotency`: as per Output Contracts

Decision and routing logic [Informative]

`accuracy` = `correct_predictions` / `total_predictions`
`roc_auc` = `trapezoidal_integral_of_TPR_over_FPR`
`pr_auc` = `trapezoidal_integral_of_precision_over_recall`
`calibration_error` = `mean_absolute(predicted_prob - empirical_freq)` over bins
`spd` = $P(y_{\text{hat}}=1 \mid A=a1) - P(y_{\text{hat}}=1 \mid A=a2)$
`eod_tpr` = `TPR(a1) - TPR(a2)`; `eod_fpr` = `FPR(a1) - FPR(a2)`
`pprev_diff` = $P(y=1 \mid A=a1) - P(y=1 \mid A=a2)$
`attack_success_rate` = `successful_adversarial_attacks` / `total_trials` at `eps` $\leq$ `adv_eps`

decision = allow if all Required checks pass and approvals satisfied;
allow_with_conditions if minor deviations within policy grace bounds; else deny

Model Risk Management [Informative]

continuous_validation: daily against goldens; adversarial suite monthly
thresholds: eval_pass_rate >= 99.5 percent → else auto_HITL for promotions
red_team_cycle: jailbreak prompts and adversarial features; model card spoof tests
rollback_policy: if eval_drop >= 1.5 percentage points for 48 h → revert
prompt_pack_id/model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: metrics, bias and robustness summaries, thresholds, variances vs. baseline, provenance results, required approvals
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL with stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

on critical bias_breach or robustness_failure affecting deployed model, open IR ticket and notify Governance A1; link to rollback recommendation.

Change Impact Assessment [Informative]

estimate_risk_delta = $w_1 \text{metric_delta} + w_2 \text{bias_severity} + w_3 \text{robustness_gap} + w_4 \text{coverage_change}$
require HITL if estimate_risk_delta >= threshold

Stakeholder Feedback Loop [Informative]

collect reviewer feedback on ValidationReport; emit FeedbackIngestionEvent at program level if enabled; never auto-train on regulated evidence.

Data Sovereignty and Legal Hold [Informative]

enforce region-aware access to datasets and reports; legal_hold=true extends retention and blocks purge.

Interfaces (links only) [Informative]

Consumes: Model Artifacts; Validation Sets (CuratedDataset)
Produces: OC-1 ValidationReport; OC-2 PromotionGateDecision; OC-3 BiasAlert; OC-4 RobustnessEvaluation

Safety and abuse prevention [Informative]

kill_switch on provenance failure or schema mismatch; rate limits per mission_id; verify SBOM for forbidden components; deny unsigned artifacts.

Testing and validation [Informative]

contract tests for OC-1..OC-4; offline replay on fixed seeds; determinism checks; fairness and robustness goldens; drift alarms and rollback.

Deployment and lifecycle [Informative]

scale by artifact size and test battery; canary new test packs; SBOM + attestations; sign all outputs.

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST AI Risk Management Framework; NIST SP 800-53 Rev. 5 (SA-11, SA-12, SA-15, PM-5); NIST SP 800-61 Rev. 2; NIST SP 800-137; NIST CSF 2.0; ISO/IEC 27002:2022; MITRE ATT&CK/D3FEND; CIS v8

MCP-Native Protocol Specification (L5) [Normative]

- **Native Protocol(s) Consumed:**

- Model Artifacts (Model Registry / OCI / Artifact Store via REST) — model binary and metadata, lineage, signatures
- Validation Sets (CuratedDataset manifests via REST/Object Storage) — versioned datasets and schemas

- **Native Protocol(s) Produced:**

- ValidationReport (REST/GraphQL/Kafka)
- PromotionGateDecision (conditional)
- BiasAlert (conditional)
- RobustnessEvaluation (optional)

- **MCP Context Fields:**

- **Required:** mission_id; role="AIValidationAgent"; intent="assess"; provenance (SPIFFE ID, signing KID, attestation); constraints (approval_required, no_prod_deploy_until, bias_thresholds, robustness); policy_refs

- **Optional:** decision_basis (evidence_refs, formulas, confidence, explanation_ref); classification (C2–C3); legal_hold
- **Enforcement Note:** Deployment gates and PEPs MUST block promotion until ValidationReport status is allow or allow_with_conditions with all required approvals; enforce no_prod_deploy_until; fairness and robustness failures require HITL or policy exception.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges and EOL dates.
- **Example payloads:** authoritative native and MCP-wrapped examples as provided above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.